

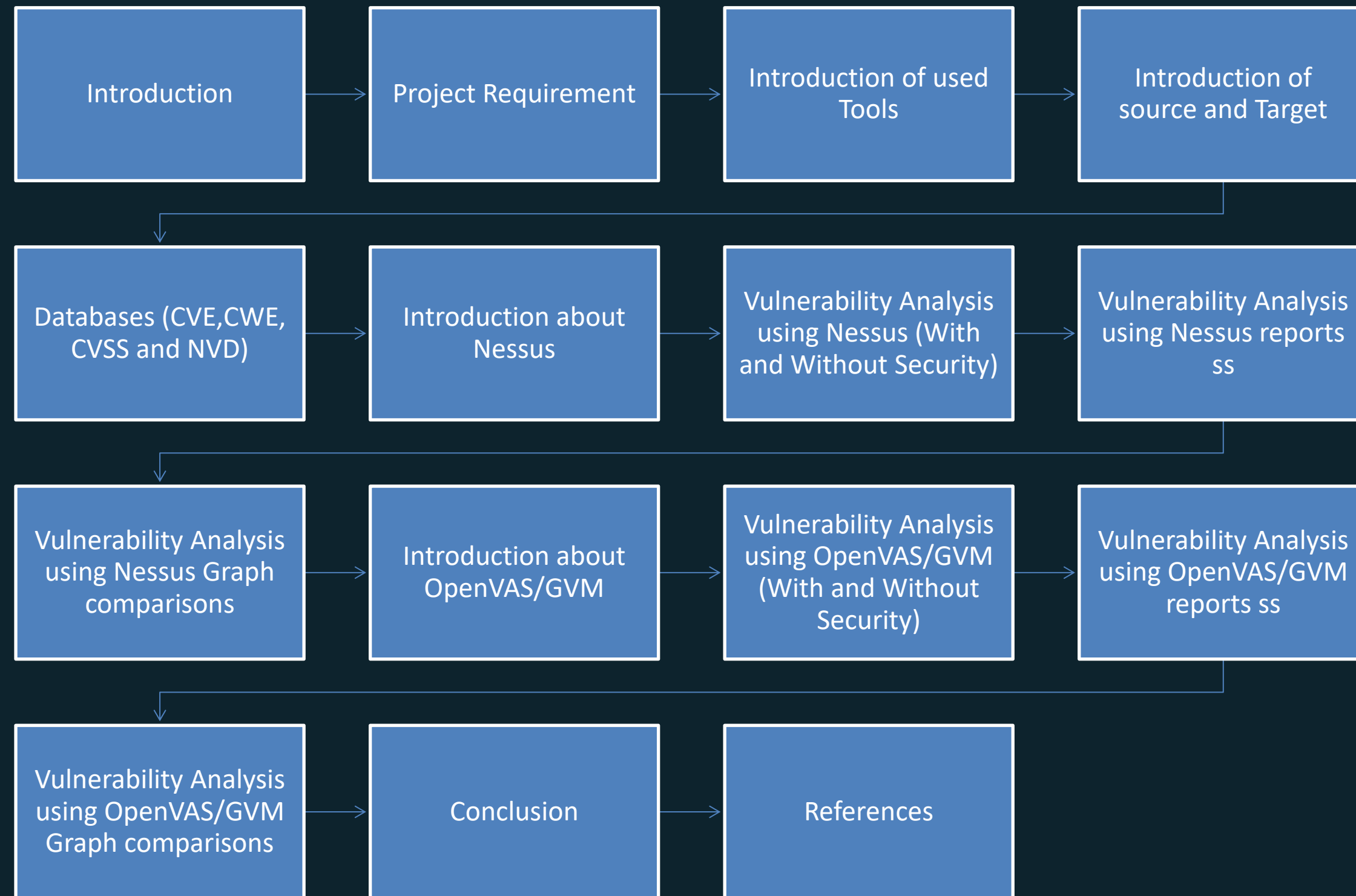
Vulnerability Analysis Using Nessus and OpenVAS/GVM

Name – Oluwatoni Oderinlo

Professor – Dimple Chauhan



Agenda



Warning



01

The information provided in this presentation is only intended for educational purpose only.

02

Any collected data during testing must be handled with strict confidentiality and used only for the purposes outlined in this project.

03

Unauthorized scanning or exploitation of system is illegal and unethical

Introduction

The objective of this project is to perform vulnerability analysis using Nessus and OpenVAS/GVM, showcasing my strong commitment to enhancing my technical proficiency and understanding of essential cybersecurity tools. My goal is to compare how well they can identify vulnerabilities in environments that are both secure and unsecure.

Project Requirements

This project will be done in a Virtual environment network and machine.
The Primary system is Kali Linux and Target system is Windows server 2022.
Two vulnerability scanning tools are used such as Tenable Nessus and OpenVAS/GVM.
Software- Kali Linux, Windows Server 2022, and Greenboro OS

Software Requirements

Kali-Linux

General	
Name:	kali-linux-2024.3-virtualbox-amd64
Operating System:	Debian (64-bit)
System	
Base Memory:	2048 MB
Processors:	2
Boot Order:	Hard Disk, Optical
Acceleration:	Nested Paging, PAE/NX, KVM Paravirtualization

Windows-Server

General	
Name:	Windows-Server
Operating System:	Windows 2022 (64-bit)
System	
Base Memory:	4048 MB
Processors:	8
Boot Order:	Floppy, Optical, Hard Disk
Acceleration:	Nested Paging, Hyper-V Paravirtualization

Greenboro

General	
Name:	Greenbone-Enterprise-TRIAL-22.04.26-VirtualBox
Operating System:	Other Linux (64-bit)
System	
Base Memory:	5120 MB
Processors:	2
Boot Order:	Hard Disk, Optical
EFI:	Enabled
Acceleration:	Nested Paging, PAE/NX, KVM Paravirtualization

Introduction of Tools Used

01

Nessus

Nessus is a widely used vulnerability assessment tool designed to identify and remediate security issues in systems, applications, and networks. It scans for misconfigurations, vulnerabilities, and compliance issues, providing detailed reports to enhance security posture

02

OpenVAS/GVM

OpenVAS, now known as Greenbone Vulnerability Manager (GVM), is an open-source vulnerability scanning tool that detects security flaws in networks, systems, and applications. It has a wide range of vulnerability tests like Nessus.

Introduction of Source and Target

Source

Is the initiating machine where the vulnerability scanning tools will be running, like running Nessus on a VM with Linux, while OpenVAS/GVM will be on a separate one.

Target

The target system is the machine or network being scanned or analyzed. It serves as the focus of vulnerability assessments.

Databases (CVE, CWE, CVSS and NVD)

CVE (Common Vulnerabilities and Exposures) is a standardized system for identifying and cataloging publicly disclosed cybersecurity vulnerabilities in software and hardware. Each vulnerability is assigned a unique CVE identifier, making it easier to track, share, and address security flaws across tools and platforms for research and finding new vulnerabilities

CWE (Common Weakness Enumeration) is a classification system that categorizes common software and hardware weaknesses. Unlike CVE, which identifies specific vulnerabilities, CWE focuses on systemic flaws that can lead to vulnerabilities, providing a framework to help developers and security professionals identify and mitigate potential security issues.

Cont. Databases (CVE, CWE, CVSS and NVD)

CVSS (Common Vulnerability Scoring System) is a standardized framework for evaluating the severity of security vulnerabilities. It assigns a score from 0 to 10, with higher scores indicating more critical issues, helping organizations prioritize remediation efforts based on the potential impact and risk.

NVD (National Vulnerability Database) is a U.S. government-managed repository maintained by the National Institute of Standards and Technology (NIST). It provides comprehensive information on vulnerabilities, including CVE details, CVSS scores, and related security metrics, supporting effective vulnerability management and risk assessment.

Ranking Parameters (CVSS)

CVSS v2.0 Ratings

Severity	Severity Score Range
Low	0.0-3.9
Medium	4.0-6.9
High	7.0-10.0

CVSS v3.x Ratings

Severity	Severity Score Range
None*	0.0
Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0

CVSS v4.0 Ratings

Severity	Severity Score Range
None*	0.0
Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0

Introduction about Nessus

Nessus is a widely used vulnerability assessment tool designed to identify security flaws, misconfigurations, and compliance issues in networks, systems, and applications. It provides detailed scans and reports, making it an essential tool for strengthening cybersecurity defenses. For the environment setup, Nessus requires installation on a supported operating system, such as Windows, Linux, or macOS.

Environment Setup -

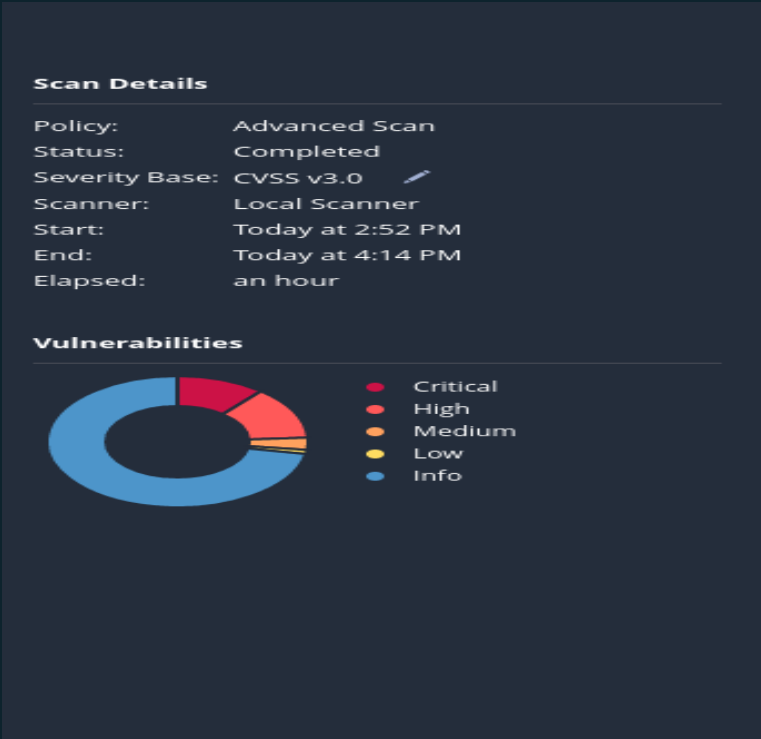
- Nessus is available for Windows, MacOS and various Linux distributions.
- Download Link:
<https://www.tenable.com/downloads/nessus?loginAttempted=true>
- Configure Nessus, Start Nessus and go to <https://localhost:8834> or <https://kali:8834> in a web browser either on Windows or Kali Linux.
- Log in using the credentials created during the installation phase, then create a scan policy.
- Start a scan and Review the results

Vulnerability Analysis using Nessus

(With and Without Security)

Task: Vulnerability analysis of the Targeted Windows server without security by disabling the firewall and antivirus

Task 1: Advanced Scan without security

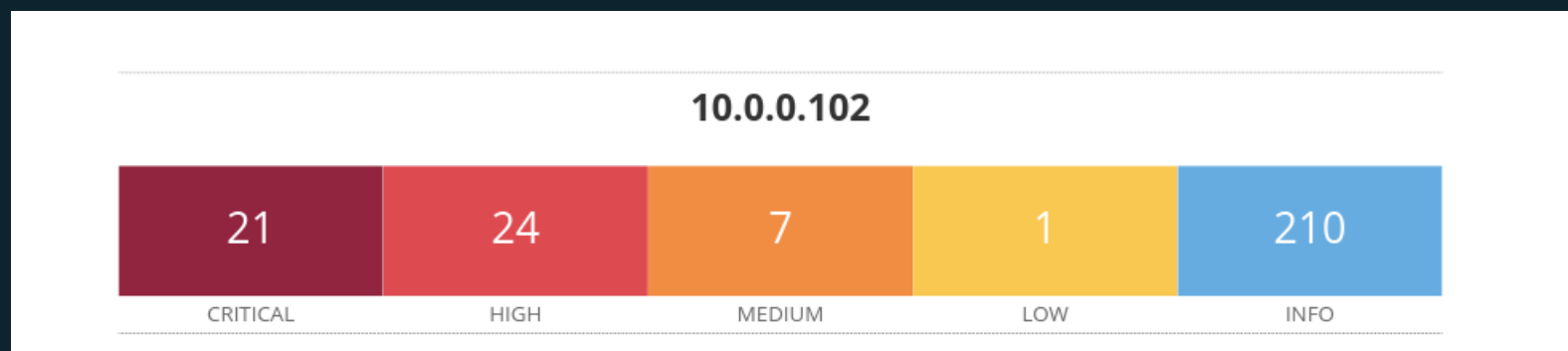


Hosts	1	Vulnerabilities	57	Remediations	5	History	1
Filter	Search Vulnerabilities						57 Vulnerabilities
Sev	CVSS	VPR	EPSS	Name	Family	Count	
MIXED	...	...	...	Microsoft Azure Stack Hci 22h2 (Multiple Issues)	Windows : Microsoft Bulletins	16	
MIXED	...	...	...	Microsoft .NET Framework (Multiple Issues)	Windows : Microsoft Bulletins	14	
MIXED	...	...	...	Microsoft Windows Server 2022 (Multiple Issues)	Windows : Microsoft Bulletins	10	
CRITICAL	...	...	...	Microsoft Azure Stack Hci (Multiple Issues)	Windows : Microsoft Bulletins	7	
MIXED	...	...	...	SSL (Multiple Issues)	General	4	
MIXED	...	...	...	Haxx Curl (Multiple Issues)	Windows	3	
MIXED	...	...	...	Microsoft Windows (Multiple Issues)	Windows : Microsoft Bulletins	2	
MIXED	...	...	...	SMB (Multiple Issues)	Misc.	2	
LOW	2.1 *	2.2	0.8939	ICMP Timestamp Request Remote Date Disclosure	General	1	
INFO	...	...	...	Microsoft Windows (Multiple Issues)	Windows	85	
INFO	...	...	...	SMB (Multiple Issues)	Windows	15	
INFO	...	...	...	HTTP (Multiple Issues)	Web Servers	9	

Summary – Vulnerabilities – 57 CVSS range 4.0–9.0 Remediation –Null

Vulnerability Analysis using Nessus report (without security)

Below shows how many vulnerabilities were found in the windows server without security



Vulnerabilities 57						
Filter	Search Vulnerabilities		57 Vulnerabilities			
☐ Sev ▼	CVSS ▼	VPR ▼	EPSS ▼	Name ▲	Family ▲	
☐ MIXED	...	...	...	16 Microsoft Azure Stack Hci 22h2 (Multiple Issues)	Windows : Microsoft Bulletins	
☐ MIXED	...	...	...	14 Microsoft .NET Framework (Multiple Issues)	Windows : Microsoft Bulletins	
☐ MIXED	...	...	...	10 Microsoft Windows Server 2022 (Multiple Issues)	Windows : Microsoft Bulletins	
☐ CRITICAL	...	...	...	7 Microsoft Azure Stack Hci (Multiple Issues)	Windows : Microsoft Bulletins	
☐ MIXED	...	...	...	4 SSL (Multiple Issues)	General	
☐ MIXED	...	...	...	2 Haxx Curl (Multiple Issues)	Windows	
☐ MIXED	...	...	...	2 Microsoft Windows (Multiple Issues)	Windows : Microsoft Bulletins	
☐ MIXED	...	...	...	2 SMB (Multiple Issues)	Misc.	
☐ LOW	2.1 *	2.2	0.8939	ICMP Timestamp Request Remote Date Disclosure	General	
☐ INFO	...	...	...	57 Microsoft Windows (Multiple Issues)	Windows	

Vulnerability Analysis using Nessus Mitigation

Without Security

163953 - KB5016627: Windows Server 2022 Security Update (August 2022)

Synopsis

The remote Windows host is affected by multiple vulnerabilities.

Description

The remote Windows host is missing security update 5016627. It is, therefore, affected by multiple vulnerabilities

- Windows Point-to-Point Protocol (PPP) Denial of Service Vulnerability (CVE-2022-35747, CVE-2022-35769)

- Windows Point-to-Point Protocol (PPP) Remote Code Execution Vulnerability (CVE-2022-30133, CVE-2022-35744)

- Windows WebBrowser Control Remote Code Execution Vulnerability (CVE-2022-30194)

Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number.

See Also

<https://support.microsoft.com/en-us/help/5016627>

<https://support.microsoft.com/help/5016627>

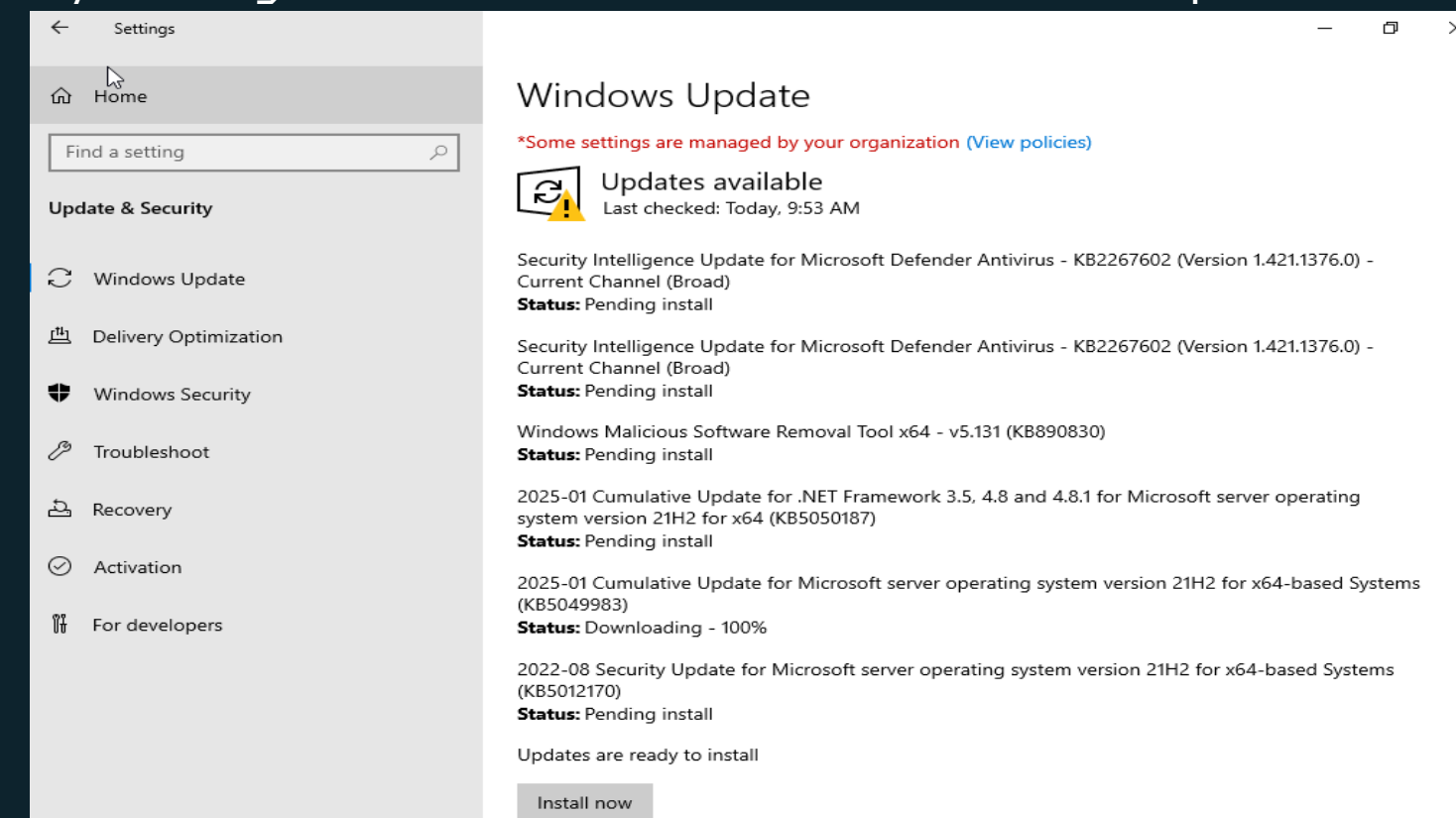
Solution

Apply Security Update 5016627

Risk Factor

Critical

To fix this vulnerability, you can enforce the message by going into settings and updating the Windows software.
By clicking the install now button under Windows Update



Vulnerability Analysis using Nessus (With Security)



Task: Vulnerability analysis of the Targeted Windows server with security.

Task 2: Advanced Scan with security

Scan Details

Policy: Advanced Scan

Status: Completed

Severity Base: CVSS v3.0

Scanner: Local Scanner

Start: Today at 2:37 PM

End: Today at 2:45 PM

Elapsed: 8 minutes

Vulnerabilities

Critical

High

Medium

Low

Info

Vulnerabilities 15									
Filter Search Vulnerabilities 15 Vulnerabilities									
☐	Sev ▼	CVSS ▼	VPR ▼	EPSS ▼	Name ▲	Family ▲	Count ▼		
☐	INFO	...	...	...	HTTP (Multiple Issues)	Web Servers	5		
☐	INFO				Nessus SYN scanner	Port scanners	2		
☐	INFO				Service Detection	Service detection	2		
☐	INFO				Common Platform Enumeration (CPE)	General	1		

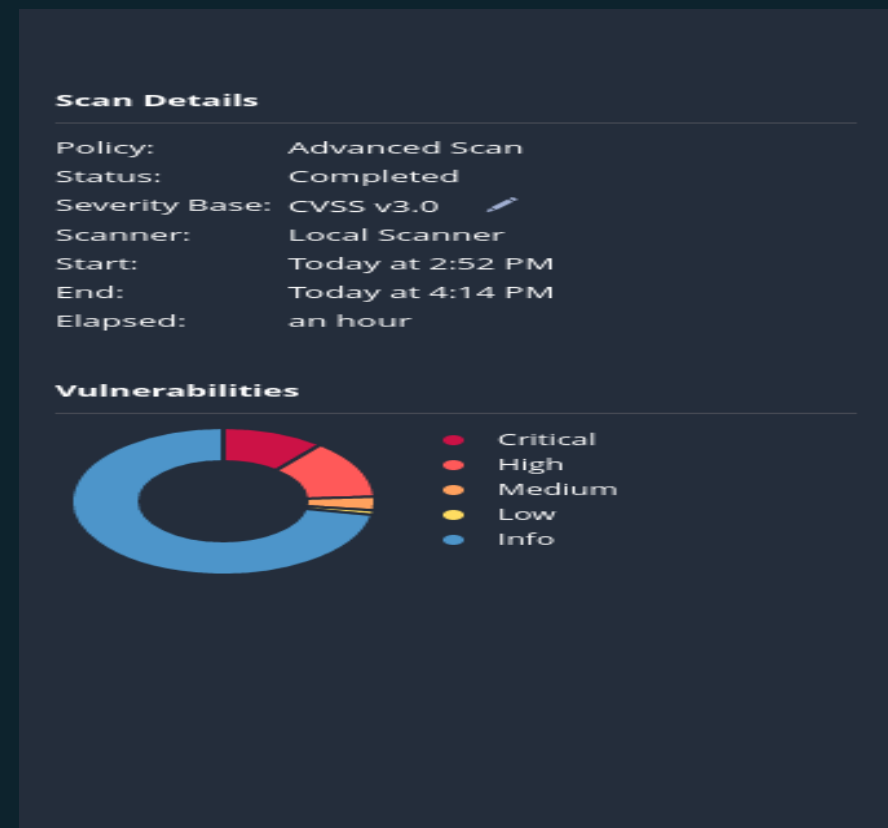
Summary – Vulnerabilities – 15 CVSS range 0.0–2.0 Remediation – Null

Vulnerability Analysis using Nessus report comparisons

- The results of the two separate Nessus Vulnerability scans on the same target but one with security enabled and the other without
- as shown in the comparison analysis.
- The security measure put in place drastically reduce the number of critical and high vulnerabilities, which demonstrates the effectiveness of have security precautions
- Without any security measure, the scans show similar medium and low vulnerabilities but with critical and high vulnerabilities.
- This shows that have security measures in place raises a system's security posture.

Vulnerability Analysis using Nessus graph comparisons

Without Security



With Security



Introduction about OpenVAS/GVM tool

- OpenVAS, part of the Greenbone Vulnerability Management (GVM) suite, is a powerful open-source vulnerability scanner widely used for identifying security flaws in systems, networks, and applications. Established in 2009 and maintained by a commercial and open-source company. It supports both authenticated and unauthenticated scans, a variety of protocols, and even custom vulnerability tests via its internal programming language.
- Properly defining scan targets and credentials ensures effective and detailed assessments, making OpenVAS/GVM a robust tool for enterprise-grade vulnerability management.

Vulnerability Analysis using OpenVAS/GVM Tool (Without Security) Report

Result overview

This scan displays Window server without security and the vulnerabilities discovered.

**Report:Wed, Jan 15, 2025 6:29 PM UTC**Done

ID: e77c86c5-812b-42ca-b547-abb093ab4951Created: Wed, Jan 15, 2025 6:29 PM UTCModified: Wed, Jan 15, 2025 7:48 PM UTCOwner: webadmin

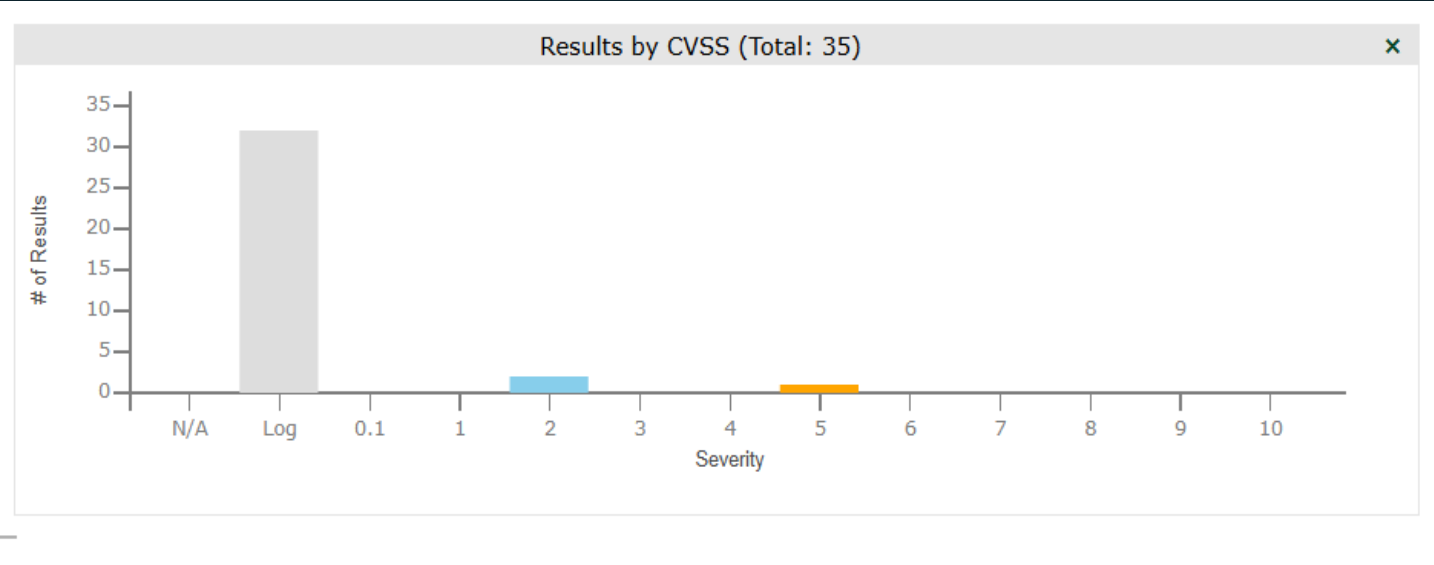
InformationResults(3 of 35)Hosts(1 of 1)Ports(1 of 7)Applications(1 of 1)Operating Systems(1 of 1)CVEs(1 of 1)Closed CVEs(19 of 19)TLS Certificates(0 of 0)Error Messages(2 of 2)User Tags(0)

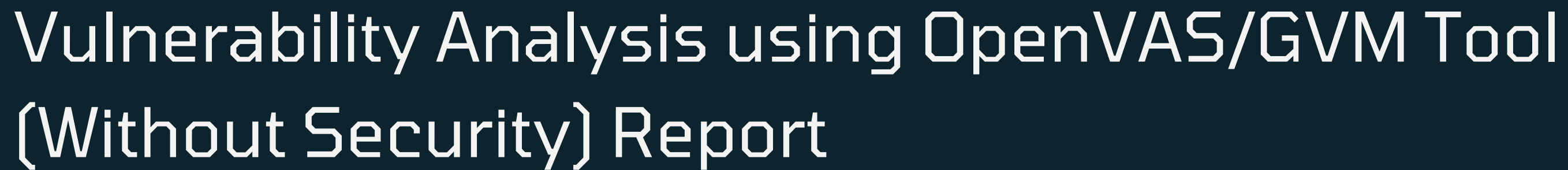
1 - 3 of 3

Vulnerability	Severity	QoD	Host IP	Name	Location	Created
DCE/RPC and MSRPC Services Enumeration Reporting	5.0 (Medium)	80 %	10.0.0.102		135/tcp	Wed, Jan 15, 2025 7:08 PM UTC
TCP Timestamps Information Disclosure	2.6 (Low)	80 %	10.0.0.102		general/tcp	Wed, Jan 15, 2025 6:59 PM UTC
ICMP Timestamp Reply Information Disclosure	2.1 (Low)	80 %	10.0.0.102		general/icmp	Wed, Jan 15, 2025 6:58 PM UTC

1 - 3 of 3

(Applied filter: apply_overrides=0 levels=hml rows=100 min_qod=70 first=1 sort=reverse=severity)





1 Result Overview

Service (Port)	Threat Level
135/tcp	Medium
general/tcp	Low
general/icmp	Low

Medium (CVSS: 5.0)
NVT: DCE/RPC and MSRPC Services Enumeration Reporting

Distributed Computing Environment / Remote Procedure Calls (DCE/RPC) or MSRPC services running on the remote host can be enumerated by connecting on port 135 and doing the appropriate queries.



Report: Sun, Jan 12, 2025 9:58 PM UTC

Done

ID: 8a3336c9-ddc9-43f1-b00b-cac7bf9dc9f6 Created: Sun, Jan 12, 2025 9:58 PM UTC Modified:

Information	Results (0 of 0)	Hosts (0 of 0)	Ports (0 of 0)	Applications (0 of 0)	Operating Systems (0 of 0)	CVEs (0 of 0)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (0 of 0)	User Tags (0)
Task Name Comment Scan Time Scan Duration Scan Status Filter Timezone	Windows Server with security Sun, Jan 12, 2025 9:59 PM UTC - Sun, Jan 12, 2025 10:02 PM UTC 0:02 h Done apply_overrides=0 levels=hml min_qod=70 Coordinated Universal Time (UTC)									

Results by CVSS (Total: 0)

Severity	# of Results
N/A	0
Log	0
0.1	0
1	0
2	0
3	0
4	0
5	0
6	0
7	0
8	0
9	0
10	0

Vulnerability Analysis using OpenVAS/GVM Tool (With Security) Report

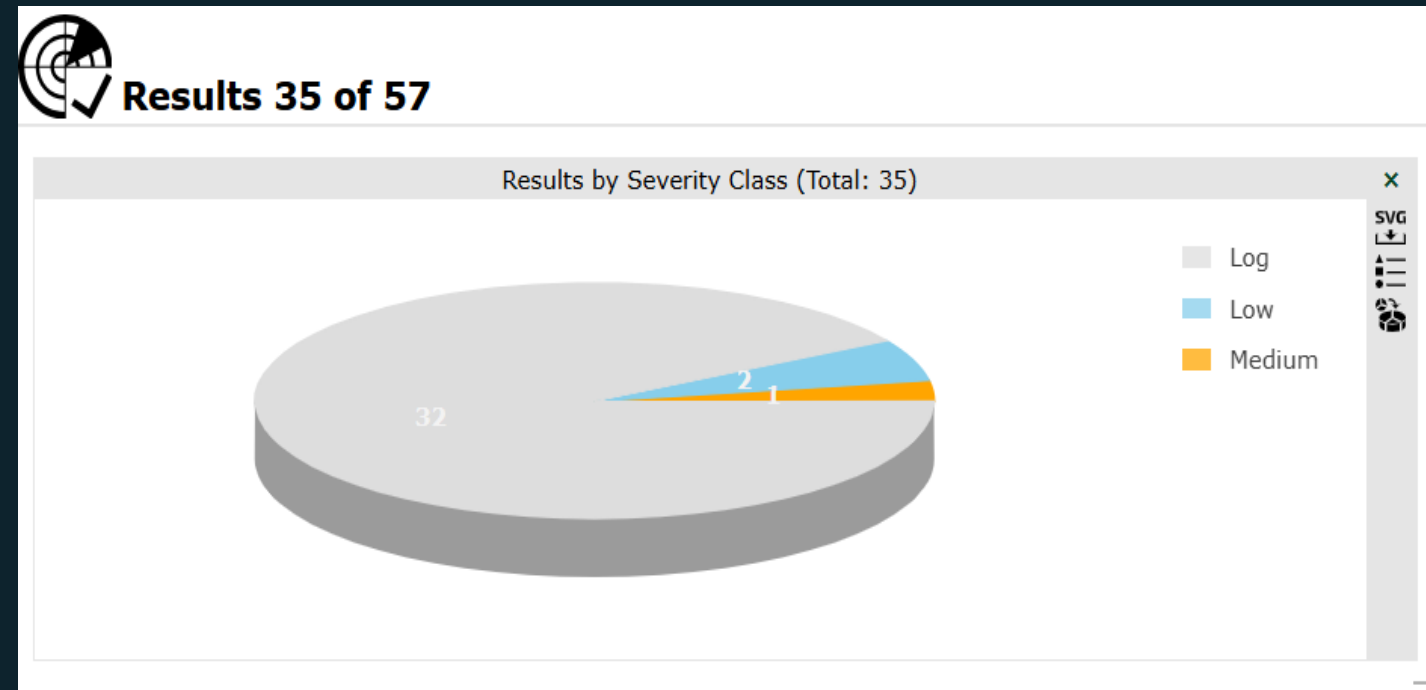
Result overview

1 Result Overview					
Host	High	Medium	Low	Log	False Positive
10.0.0.102	0	0	1	0	0
Total: 1	0	0	1	0	0

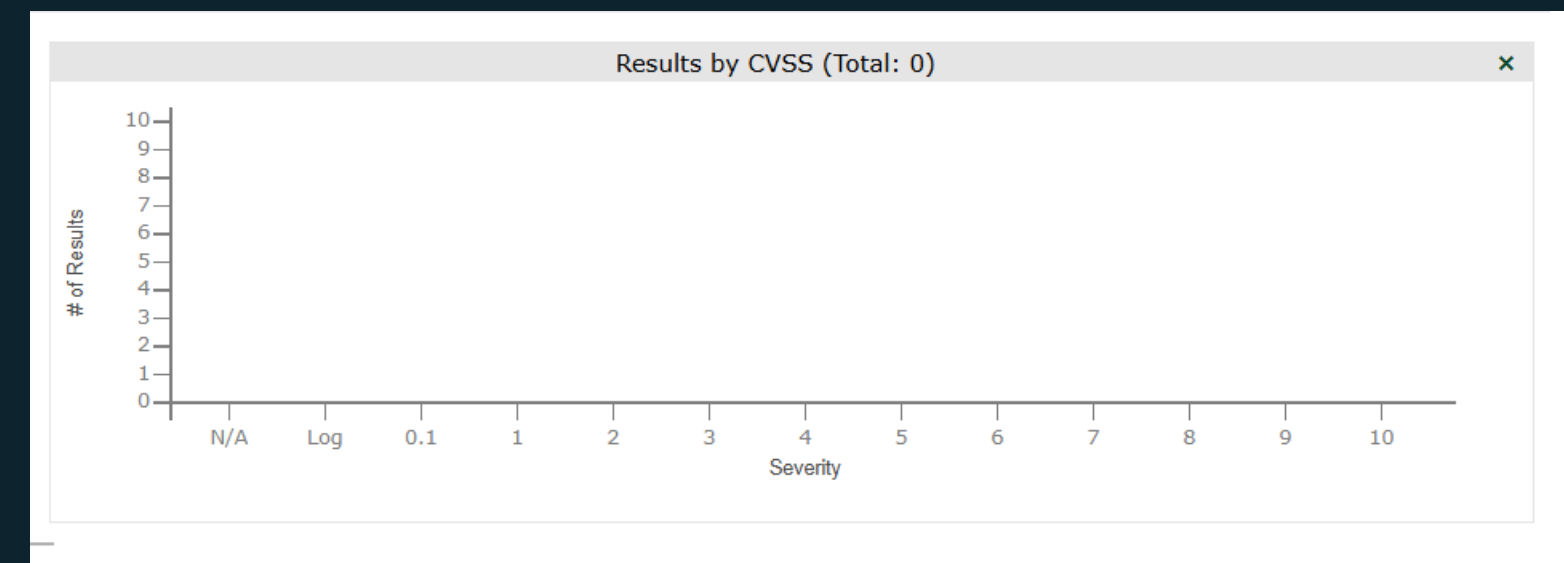
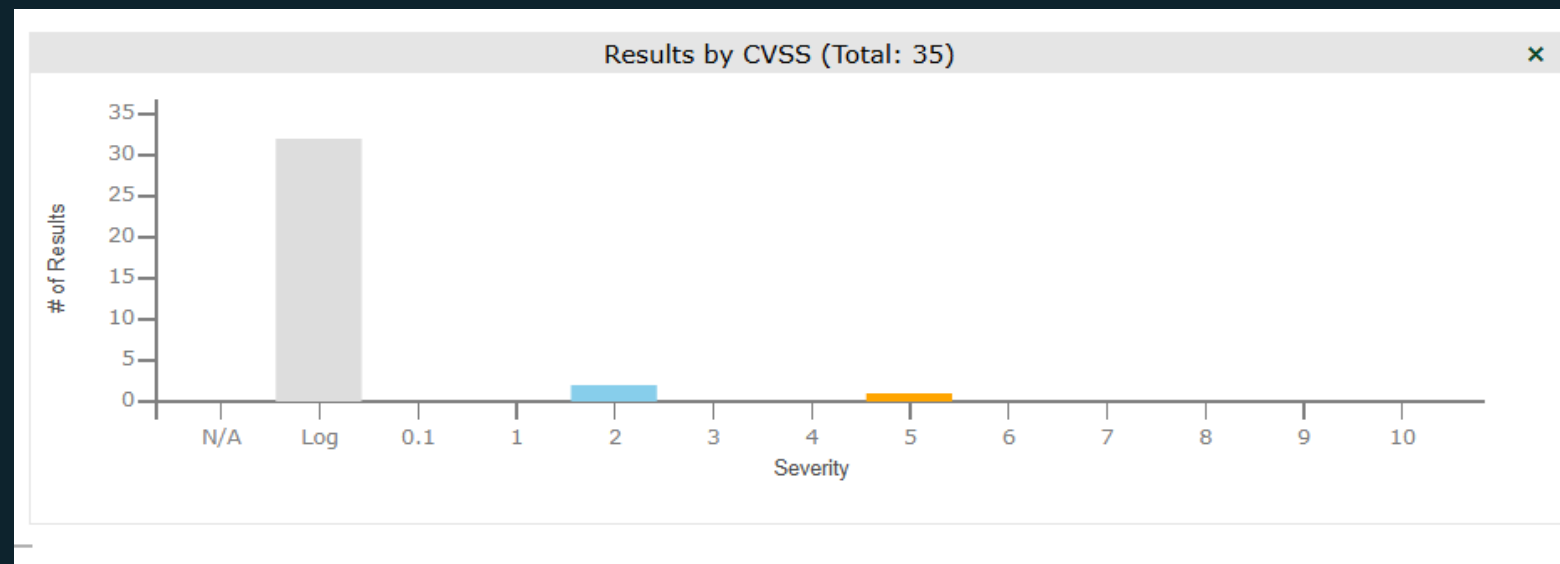
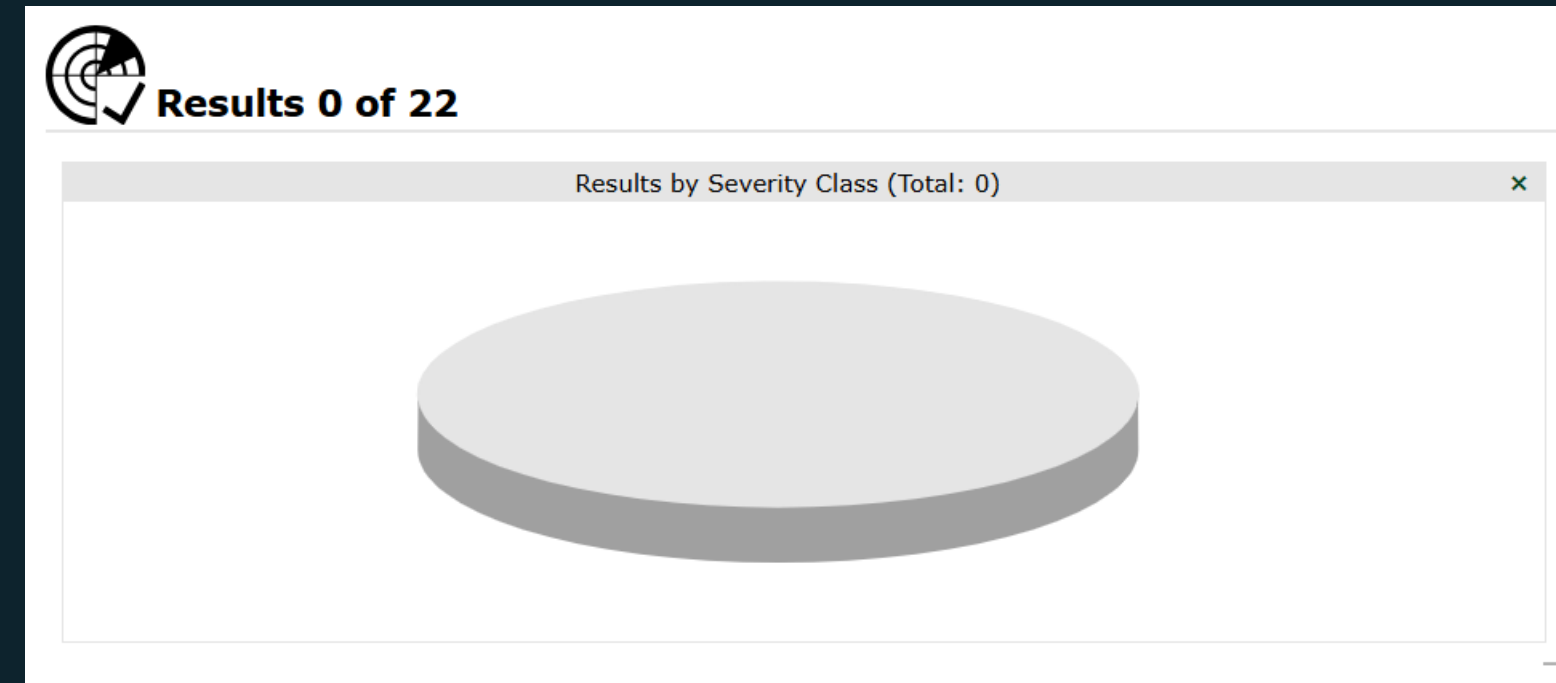
Host	High	Medium	Low	Log	False Positive
Total: 0	0	0	0	0	0

Vulnerability Analysis using OpenVAS/GVM report comparisons

Without Security



With Security



Vulnerability Analysis using OpenVAS/GVM reports comparisons

- The results of the two separate OpenVAS/GVM scans on the same target but one with security enabled and the other without
- as shown in the comparison analysis.
- The security measure put in place drastically reduce the number of critical and high vulnerabilities, which demonstrates the effectiveness of have security precautions
- With any security measure, the scans show no vulnerability but the one without security showed more of low and medium vulnerabilities.
- There was a total of 19 vulnerabilities discovered in the scan without security and 0 vulnerabilities with security.

Conclusion

AI analyzes historical data to identify patterns and trends that indicate potential future attacks.

Reference

- https://medium.com/@King_Night/understanding-the-differences-between-cve-cwe-and-nvd-e2db34633da8
- [https://www.balbix.com/insights/understanding-cvss-scores/#:~:text=The%20Common%20Vulnerability%20Scoring%20System%20\(CVSS\)%20is%20a%20standardized%20framework,scores%20meaning%20more%20severe%20issues.](https://www.balbix.com/insights/understanding-cvss-scores/#:~:text=The%20Common%20Vulnerability%20Scoring%20System%20(CVSS)%20is%20a%20standardized%20framework,scores%20meaning%20more%20severe%20issues.)
- <https://nvd.nist.gov/vuln-metrics/cvss>
- <https://securitytrails.com/blog/openvas-vulnerability-scanner>

THANK YOU